Private Identity LLC
13331 Signal Tree Ln
Potomac MD 2854
privateid.com

Submitted to:
Centers for Medicare & Medicaid Services
Department of Health and Human Services
7500 Security Boulevard
Baltimore, MD 21244

Response to CMS-0042-NC – RFI on the Health Technology Ecosystem

In Collaboration With:

The CARIN Alliance

Contact for Follow-Up:

Clayton Roth, President
Private Identity LLC
clayton@privateid.com
(925) 878-1435

June 10, 2025

Mr. Clayton Roth, President
Private Identity LLC
13331 Signal Tree Ln
Potomac MD 2854

The Honorable Stephanie Carlton, Deputy Administrator
Centers for Medicare & Medicaid Services
Department of Health and Human Services
7500 Security Boulevard
Baltimore, MD 21244

RE: CMS-0042-NC – Request for Information on the Health Technology Ecosystem

Dear Deputy Administrator Carlton,

On behalf of Private Identity LLC, I appreciate the opportunity to submit this response to the Centers for Medicare & Medicaid Services' (CMS) Request for Information on the Health Technology Ecosystem (CMS-0042-NC). We commend CMS for its vision to strengthen program integrity, interoperability, delegated access, and patient trust through modern digital infrastructure. Private Identity is an active Member of the CARIN Alliance. Our response reflects our commitment to the CARIN vision: empowering consumers with access, control, and auditability over their health information using open, privacy-preserving standards.

We have structured our response to align with the five stakeholder domains defined in the RFI—Technology and Trust Frameworks, Patients and Caregivers, Value-Based Care Organizations, Payers and Vendors, and Providers. Across each, we detail how iTrust Identity, our standards-based credential platform, enables CMS to enforce identity, intent, and consent at scale using NIST-compliant digital credentials, HL7 FHIR Consent, and real-time audit infrastructure.

Private Identity stands ready to support CMS in moving from policy aspiration to operational enforcement—replacing passive controls with cryptographic trust, and assumptions with verifiable authorization.

We welcome the opportunity to engage further and assist CMS in piloting and operationalizing these capabilities in collaboration with federal, state, and private sector partners.

Sincerely,
Clayton Roth
President

TABLE OF CONTENTS

1. Credential-Based Infrastructure for Compliance, Access, and Public Trust (TD-3 through TD-9) 5
1.1 From Policy Vision to Infrastructure Execution 5
1.2 Federated, Credential-Bound Identity for National Scale 5
1.3 Mapping CMS-9884-P to Credential Enforcement 5
1.4 Delegation, Audit, and Equity by Design 6
1.5 Federated Trust Governance and Metadata Standards 6
1.6 Compliance Standards Aligned to CMS Goals 7
1.7 Recommendations to CMS, ONC, and CCIIO 7
1.8 Trust Is Enforcement—Not Just Aspiration 8
2. Enabling Seamless Data Access, Interoperability, and Consent 9
2.1 From Patient Access to Policy Enforcement 9
2.2 Federated Credentials for Trustworthy Access 9
2.3 Consent That Can Be Proven—and Revoked 10
2.4 Delegated Access That Works 10
2.5 CMS Use Case Alignment 11
2.6 Certification-Ready Standards Compliance 11
2.7 Recommendations to CMS and ONC 12
2.8 Access You Can Prove—Not Just Grant 12
3. Credential-Bound Navigation, Attribution, and Delegation in Value-Based Care 13
3.1 A Fragmented Ecosystem Requires Credential-Based Infrastructure 13
3.2 Federated Credential Navigation Across CMS Programs 13
3.3 Credential-Linked Workflows for Intake and Scheduling 14
3.4 Verifiable Attribution and Consent Chaining in VBC 14
3.5 CMS Use Cases and Credential Enforcement 14
3.6 Certification-Ready Standards for VBC Integration 15
3.7 Recommendations to CMS and ONC 15
3.8 Navigation Is Governance—When Credentialed 16
4. Enabling Trust Infrastructure for Fraud Resistance and Policy Enforcement 17
4.1 Fraud Is a Systemic Risk—Governance Must Be Structural 17
4.2 Detecting Synthetic Identity Without Biometrics or Central Storage 17
4.3 Intent Verification on Every Transaction 18
4.4 Federated Credential Validation Across Agencies 18
4.5 Real-Time Logging, Auditability, and Exportability 18
4.6 TEFCA Policy Enforcement at the Identity Layer 19
4.7 Recommendations to CMS, ONC, and the TEFCA RCE 19
4.8 From Passive Control to Real-Time Policy Execution 20
5. Provider Integration, Delegated Consent, and Certification-Grade Enforcement 21
5.1 Providers Need Verifiable Trust at the Point of Care 21
5.2 SMART-on-FHIR and Credential Enforcement at the Point of Care 21

5.3 Scoped Delegation and Verifiable Consent 22
5.4 Certification-Ready Integration for HIT Vendors and Providers 22
5.5 TEFCA-Grade Enforcement for Network Participants 23
5.6 Recommendations to CMS, ONC, and the RCE 23
5.7 Governance Begins at the Credential Level 24

1. Credential-Based Infrastructure for Compliance, Access, and Public Trust (TD-3 through TD-9)

Private Identity LLC – Response to CMS-0042-NC
Private Identity LLC is an engaged and active Member of the CARIN Alliance.

1.1 From Policy Vision to Infrastructure Execution

Private Identity strongly supports CMS's objective to build an enforceable, equitable, and interoperable health technology ecosystem. We believe trust must be implemented as a **system function**—not just a policy aspiration. That's why we developed **iTrust Identity**, a credential-based infrastructure platform purpose-built for CMS-regulated programs. It operationalizes CMS-9884-P by enforcing identity, consent, and delegation in real time.

As an enthusiastic Member of the CARIN Alliance, we align deeply with its vision of open, standards-based digital identity and consent frameworks for consumers and stakeholders across the health ecosystem.

1.2 Federated, Credential-Bound Identity for National Scale

iTrust Identity enables NIST SP 800-63A IAL2 identity credentialing and SP 800-63B AAL2 authentication using secure, privacy-preserving methods. Credentials are provisioned through OpenID Connect and OAuth 2.0 sessions (PKCE-enforced), and include:

- `sub`: unique identity reference
- `acr`: assurance level
- `auth_time`: authentication timestamp
- `trust_level`: issuer-defined trust classification
- Signed FHIR Consent and OAuth tokens
- Homomorphic tokenization (512-float vectors, non-reversible) for deduplication across ACA, CHIP, and Medicaid

Private Identity, as a CARIN Alliance Member, promotes federated credentials that are portable, verifiable, and fully privacy-preserving.

1.3 Mapping CMS-9884-P to Credential Enforcement

We operationalize CMS-9884-P through enforceable infrastructure:

CMS Policy Need	iTrust Enforcement Mechanism
SEP Document Validation	ECDSA-signed uploads + FHIR Provenance.agent linkage
Broker Oversight	IAL2 credential + PractitionerRole.identifier + AuditEvent logging
Premium Payment Confirmation	OAuth-bound Task + `auth_time` freshness enforcement
Auto-Enrollment Controls	Credential session validation + real-time intent binding
Identity Reuse Across Programs	Federated credential metadata, deduplicated using HT vectors

All mechanisms are standards-based and technically certifiable today.

1.4 Delegation, Audit, and Equity by Design

We treat **delegation and auditability** as first-class system functions:

- Delegated sessions via `RelatedPerson` or `PractitionerRole` using OAuth + FHIR Consent
- Real-time revocation using Consent.status and introspection endpoints
- Every action is logged with cryptographic attribution: `AuditEvent`, `Provenance.agent`, and `onBehalfOf`

This architecture ensures CMS can enforce **who did what, for whom, and why**—in real time, with cryptographic confidence.

As a CARIN Alliance Member, Private Identity champions equity through secure delegation and accessibility-focused design.

1.5 Federated Trust Governance and Metadata Standards

iTrust Identity uses federated trust architecture:

- **UDAP**: Credential issuer registration and metadata publication
- **JWKS & OpenID Discovery**: Signature verification and trust anchor validation

- **Credential claims**: Include issuer, assurance level, purpose scope, and expiration

This model empowers CMS to **govern without centralizing**, enabling real-time trust validation across exchanges, states, and QHINs.

1.6 Compliance Standards Aligned to CMS Goals

Layer	Standard	Functionality
Identity Proofing	NIST SP 800-63A (IAL2)	Verified digital identity for CMS workflows
Authentication	NIST SP 800-63B (AAL2)	Secure session binding (PKCE, passkey, biometrics)
Consent Enforcement	HL7 FHIR Consent + JWS + UDAP	Structured, revocable access control
Session Security	OAuth 2.0 + OpenID Connect	Token-based delegation and introspection
Action Attribution	FHIR AuditEvent + Provenance	Full traceability of actor, intent, and purpose
Identity Deduplication	Homomorphic tokens + similarity scoring	Privacy-preserving detection of synthetic identities

1.7 Recommendations to CMS, ONC, and CCIIO

1. **Mandate IAL2/AAL2 credentialing** and signed Consent + Provenance for all identity-sensitive CMS workflows

2. **Certify OAuth2 + Consent enforcement** under ONC Health IT Certification (Consent.revocation, sub introspection)

3. **Fund pilots** for delegated access and SEP verification using iTrust Identity across states and QHINs

4. **Launch a CMS Trust Anchor Registry** for identity issuers using UDAP + JWKS metadata

5. **Require AuditEvent NDJSON export** for credential-bound actions affecting eligibility or payment

1.8 Trust Is Enforcement—Not Just Aspiration

Private Identity LLC believes CMS must transition from policy-driven goals to system-level enforcement. We are ready to support CMS with a credentialed, certifiable, federated trust fabric that can scale across programs.

As an engaged and active Member of the CARIN Alliance, we bring open standards, practical experience, and privacy-by-design principles to this national challenge.

---

2. Enabling Seamless Data Access, Interoperability, and Consent

Private Identity LLC – Response to CMS-0042-NC
Private Identity LLC is an engaged and active Member of the CARIN Alliance.

2.1 From Patient Access to Policy Enforcement

Private Identity LLC fully supports CMS's vision that patient access must be **secure, seamless, and enforceable**—not just available. iTrust Identity makes this real by binding each access session to a **verified identity**, a **signed FHIR Consent**, and an **audit trail**.

Our credentialing model enforces identity assurance (IAL2), session security (AAL2), and consent scoping (FHIR + OAuth). This transforms consent from a checkbox into a **cryptographically signed contract**—verifiable, revocable, and enforceable in real time.

As a committed CARIN Alliance Member, Private Identity helps translate digital rights into **governable access**.

2.2 Federated Credentials for Trustworthy Access

Each iTrust credential is:

- **Proofed at IAL2** (government ID, biometric liveness, phone verification)
- **Authenticated at AAL2** (FIDO2 passkey or biometric fallback)
- Issued via **OAuth 2.0 + OpenID Connect**, with claims:
    - `sub`: unique identity reference
    - `acr`: assurance level

    - `auth_time`: session time
    - `trust_level`: federated metadata
- Usable across Blue Button 2.0 APIs, Medicaid portals, and payer interfaces
- Enforced via **PKCE**, **signed FHIR Consent**, and session-level token introspection

These portable credentials empower patients while ensuring **CMS can govern access—not just grant it**.

Private Identity, as a CARIN Alliance Member, promotes open identity standards that protect individuals and align with CMS goals.

2.3 Consent That Can Be Proven—and Revoked

We use **FHIR R4 Consent resources** as cryptographic enforcement tools. Each consent record:

- Specifies actors (`provision.actor`), data (`provision.data`), and purpose (`provision.purpose`)
- Is signed using **JWS** and linked to an OAuth session
- Is dynamically enforceable through **token introspection** and **Consent.status**

All data access is logged using **FHIR AuditEvent** and **Provenance**, producing CMS-readable NDJSON exports.

When a patient revokes consent, the token becomes invalid in real time—enabling CMS to meet the **revocation and intent-binding** mandates in CMS-9884-P and TEFCA.

As a CARIN Alliance Member, we believe **consent must be computable and revocable—not passive**.

2.4 Delegated Access That Works

iTrust Identity supports verifiable delegation:

- **Caregivers** act via `RelatedPerson` and OAuth tokens signed by the primary user's credential
- **Brokers and Navigators** act under `PractitionerRole` delegation with defined scope

- **Consent chains** establish accountability and support `onBehalfOf` session attribution
- **Revocation** endpoints terminate delegated sessions instantly
- **Audit logs** capture every access event, including proxy and purpose

This enables compliant delegated access across Medicaid redeterminations, ACA enrollments, and SEP transitions.

As an active Member of the CARIN Alliance, Private Identity ensures trust extends to every caregiver and proxy user.

2.5 CMS Use Case Alignment

Use Case	iTrust Identity Enforcement
Blue Button API Access	Credentialed SMART launch + signed Consent + PKCE enforcement
Caregiver Delegation	RelatedPerson session + FHIR Consent + OAuth `onBehalfOf`
SEP Submission by Broker	PractitionerRole credential + signed document + Provenance + Consent
Medicaid Redetermination	Delegated credential + scoped Consent + real-time audit trail
Payer-to-Payer API Exchange	Consent + OAuth `purpose_of_use` claim + credential metadata enforcement

Each of these workflows is actively supported and exportable in **NDJSON** format.

2.6 Certification-Ready Standards Compliance

Capability	Standard	CMS Function
Identity Proofing	NIST SP 800-63A (IAL2)	Individual and delegated credential issuance
Authentication	NIST SP 800-63B (AAL2)	Secure login + session security

Capability	Standard	CMS Function
Consent Enforcement	HL7 FHIR Consent + JWS + UDAP	Signed, revocable, structured access control
Trust Federation	OpenID Connect + JWKS + UDAP	Credential introspection + issuer verification
Data Auditability	FHIR AuditEvent + Provenance	Full traceability, compliant with TEFCA and HIPAA

We recommend CMS and ONC certify these functions in the **ONC HIT Certification Program**, with special attention to dynamic consent revocation, actor verification, and session-level audit export.

2.7 Recommendations to CMS and ONC

1. Mandate **OAuth-bound FHIR Consent** across all CMS APIs
2. Require **Exchange Purpose tagging** in OAuth `purpose_of_use` and FHIR Consent
3. Certify **dynamic introspection + revocation endpoints** for delegated access
4. Fund **caregiver delegation pilots** using credentialed sessions across state Medicaid programs
5. Launch a **CMS Trust Anchor Registry** for verifying credential issuers using JWKS and UDAP metadata

2.8 Access You Can Prove—Not Just Grant

Access is not empowerment unless it's backed by enforceable trust. Private Identity transforms the access model: every session is credentialed, every delegation is signed, and every consent is verifiable.

As a **proud Member of the CARIN Alliance**, Private Identity stands ready to work with CMS, ONC, and TEFCA participants to ensure **access is provable, private, and governed.**

---

3. Credential-Bound Navigation, Attribution, and Delegation in Value-Based Care

Private Identity LLC – Response to CMS-0042-NC
Private Identity LLC is an engaged and active Member of the CARIN Alliance.

3.1 A Fragmented Ecosystem Requires Credential-Based Infrastructure

Value-based care (VBC) cannot succeed without verifiable identity, consent, and attribution. Providers and patients are too often burdened with manual coordination, untracked delegations, and undocumented access decisions.

Private Identity LLC addresses this gap with **iTrust Identity**, a credentialed enforcement layer that enables CMS to govern every action, every delegation, and every quality outcome—cryptographically and in real time.

As an active Member of the CARIN Alliance, we believe **governance begins with identity—and succeeds with delegation you can prove**.

3.2 Federated Credential Navigation Across CMS Programs

iTrust Identity enables every CMS-recognized actor (patients, brokers, caregivers, providers) to operate across ACA, Medicaid, and Medicare with a **single, portable, IAL2/AAL2 credential**. Key capabilities include:

- Identity proofing (NIST SP 800-63A) and authentication (SP 800-63B)
- PKCE-enforced OAuth sessions with trust metadata: `sub`, `acr`, `auth_time`, `trust_level`
- Consent-scoped access via FHIR Consent.provision.actor and OAuth delegation
- Revocable sessions and token introspection endpoints
- Full traceability via FHIR AuditEvent and Provenance logs

As a CARIN Alliance Member, we believe cross-program navigation should be federated, trusted, and logged—without repeated verification or form-based delegation.

3.3 Credential-Linked Workflows for Intake and Scheduling

We embed credentialed trust into real-world navigation workflows:

- **Pre-intake**: Credential retrieves verified demographics via FHIR Questionnaire and Coverage
- **Scheduling**: FHIR Slot filtered by actor's role, credential scope, and access metadata
- **Workflow execution**: FHIR Task (e.g., "Upload SEP Doc") signed with OAuth token, linked to signed Consent and AuditEvent
- **Transitions**: Brokers or caregivers act under scoped, revocable Consent with `onBehalfOf` logging

With this structure, CMS can **trace every access event to an actor, a credential, and a signed authorization.**

3.4 Verifiable Attribution and Consent Chaining in VBC

iTrust Identity supports VBC-specific functions with cryptographic proof:

- Quality data entries (e.g., Observation, Encounter) are **signed by the provider's credentialed session**
- Patients delegate care coordination via FHIR Consent.provision.actor
- Consent chains trace permission through RelatedPerson or PractitionerRole
- NDJSON $export supports CMS audits and quality score verification
- Provenance ensures the actor, intent, and session are all embedded in the data

This transforms CMS's trust in VBC programs from **self-attestation to verified attribution**.

3.5 CMS Use Cases and Credential Enforcement

Use Case	**iTrust Identity Enforcement**
SEP Enrollment Navigation	FHIR Task + Consent + AuditEvent signed by credential
Broker Delegation	PractitionerRole + OAuth session + provision-scoped Consent

Use Case	iTrust Identity Enforcement
Medicaid Redetermination	RelatedPerson credential + revocable Consent + `onBehalfOf` traceability
ACO Attribution + Quality Scoring	NDJSON $export + credentialed Observation + signed Provenance
Plan Appeals	Consent-authorized form execution + ECDSA-signed Task + AuditEvent

Each access is **logged, signed, and traceable**—no more blind delegation or unverifiable entries.

3.6 Certification-Ready Standards for VBC Integration

Component	Standard	Functionality
Identity Credentialing	NIST SP 800-63A (IAL2)	Government ID + device + biometric verification
Authentication	NIST SP 800-63B + PKCE	Device-bound OAuth session with expiry control
Consent Enforcement	FHIR Consent (R4) + JWS	Scoped, actor-specific, revocable delegation
Action Traceability	FHIR AuditEvent + Provenance	Actor + purpose + timestamp + outcome logged
CMS Export Integration	FHIR $export + NDJSON	Credential-bound quality measure submission
HIT Interoperability	SMART-on-FHIR + UDAP	ONC-certifiable integration across EHRs and payers

3.7 Recommendations to CMS and ONC

1. Require **OAuth-scoped Consent enforcement** across Medicaid and ACA navigation workflows

2. Mandate **credential-linked attribution** for all Observation, Condition, and Encounter data in VBC programs

3. Certify **Consent.provision.actor** and **onBehalfOf logging** under ONC HIT Certification

4. Launch **delegated navigation pilots** for brokers, caregivers, and caseworkers in ACOs and state Medicaid platforms

5. Establish a **Trust Anchor Registry** to validate credential metadata (issuer, trust_level, purpose) across systems

3.8 Navigation Is Governance—When Credentialed

Credential-based enforcement turns navigation into governance. iTrust Identity enables CMS to **prove who acted, under what authority, and with what consent**—in real time and at national scale.

As a CARIN Alliance Member, Private Identity is committed to making VBC accountable, equitable, and cryptographically provable.

---

4. Enabling Trust Infrastructure for Fraud Resistance and Policy Enforcement

Private Identity LLC – Response to CMS-0042-NC
Private Identity LLC is an engaged and active Member of the CARIN Alliance.

4.1 Fraud Is a Systemic Risk—Governance Must Be Structural

CMS cannot eliminate identity fraud and synthetic IDs with paper attestations or disconnected portals. It requires enforceable, cryptographic infrastructure.

Private Identity LLC, through its **iTrust Identity** platform, delivers fraud resistance as a system function—not a retrospective review. We use **privacy-preserving homomorphic tokenization**, OAuth-bound identity proofs, and real-time auditability to ensure every action is tied to a verified, credentialed actor.

As a CARIN Alliance Member, we believe **privacy and fraud prevention can—and must—coexist** in government programs.

4.2 Detecting Synthetic Identity Without Biometrics or Central Storage

iTrust Identity offers fraud detection without sacrificing privacy:

- **Homomorphic tokens**: On-device generation of 512-float, irreversible identity vectors

- **No biometric storage**: No images or biometric templates ever leave the user's device

- **Similarity scoring**: Approximate deduplication using cosine distance or ANN across ACA, Medicaid, and CHIP

- **Cross-program deduplication**: Federated CredentialMatch scores computed in real time

- **Client-side cryptography**: Reduces attack surfaces and enforces local compliance

This allows CMS to identify duplicate or suspicious identities **without storing or exposing any sensitive data**.

As a CARIN Alliance Member, we lead with privacy-first design to earn trust while detecting fraud.

4.3 Intent Verification on Every Transaction

Private Identity ensures every action is bound to intent via:

- **ECDSA signatures** on each submitted FHIR Task or document
- OAuth metadata: `sub`, `acr`, `auth_time`, `trust_level`
- FHIR Consent: Links authorization to action and actor
- Audit logs: Every event recorded in `AuditEvent.agent` and `Provenance.agent`

These layers make identity and authorization **provable—not presumed**.

4.4 Federated Credential Validation Across Agencies

iTrust Identity enables **federated trust governance** across states, payers, and QHINs:

- **UDAP dynamic client registration**
- **OpenID Connect discovery endpoints**
- **JWKS URI verification**
- Credential metadata includes issuer type, assurance level, expiration, delegation permissions

This allows CMS to validate credential provenance and assurance **at runtime**, without central issuance.

4.5 Real-Time Logging, Auditability, and Exportability

All credential-bound events are **auditable and exportable**:

- **FHIR AuditEvent**: Captures session metadata (actor, time, outcome)
- **FHIR Provenance**: Captures delegation details (`agent`, `onBehalfOf`, `Consent.policy`)
- **NDJSON $export**: Logs exported for CMS audit, compliant with TEFCA
- **Exchange Purpose enforcement**: Purpose-of-use is enforced across OAuth and Consent

This provides CMS with a **nationwide view of credentialed, delegated access**—fully structured and certifiable.

4.6 TEFCA Policy Enforcement at the Identity Layer

iTrust Identity enforces TEFCA Exchange Purpose and Flow-Down Agreements with:

TEFCA Policy Element	iTrust Enforcement Mechanism
Exchange Purpose	OAuth `purpose_of_use` + FHIR Consent.provision.purpose
Flow-Down Agreement	Credential metadata + policy-scoped session + signed logs
Trust Validation	CMS Trust Anchor Registry + OIDC issuer discovery + JWKS validation
Delegated Attribution	FHIR Provenance.onBehalfOf + AuditEvent.agent
Revocation and Audit	Consent revocation + OAuth token introspection + NDJSON export

With this structure, CMS doesn't just permit exchange—it governs it.

As a CARIN Alliance Member, Private Identity ensures every delegated access is traceable and governed under TEFCA policy.

4.7 Recommendations to CMS, ONC, and the TEFCA RCE

1. Establish a **CMS Trust Anchor Registry** for federated identity issuers (states, QHINs, MCOs)

2. Require **OAuth purpose_of_use** tagging and session enforcement for delegated access

3. Certify **FHIR AuditEvent + Provenance export** in the ONC HIT Certification Program

4. Fund **encrypted vector deduplication pilots** across Medicaid and ACA platforms

5. Adopt **credential metadata standards** (trust_level, issuer_type) to support policy-driven enforcement

4.8 From Passive Control to Real-Time Policy Execution

Private Identity replaces ambiguity with attribution. Every credential is signed. Every action is logged. Every purpose is enforced.

As an engaged and active Member of the CARIN Alliance, we are committed to making fraud detection, intent verification, and delegated governance enforceable at scale—while preserving privacy and dignity for all participants.

---

5. Provider Integration, Delegated Consent, and Certification-Grade Enforcement

Private Identity LLC – Response to CMS-0042-NC
Private Identity LLC is an engaged and active Member of the CARIN Alliance.

5.1 Providers Need Verifiable Trust at the Point of Care

Digital trust in clinical workflows breaks down without infrastructure for verified identity, consent, and delegation. Providers are often asked to act on behalf of patients, but without credential validation or audit capability, compliance and governance suffer.

Private Identity's **iTrust Identity** enables providers, brokers, caregivers, and caseworkers to act under **scoped, signed, revocable authority**, traceable to each action they perform—clinical or administrative.

As an active Member of the CARIN Alliance, we believe trust begins at the **credential layer** and must extend to the **EHR execution layer**.

5.2 SMART-on-FHIR and Credential Enforcement at the Point of Care

iTrust Identity fully supports **SMART-on-FHIR workflows**, both EHR-launched and standalone:

- **OAuth 2.0 Authorization Code Flow** with PKCE
- OpenID Connect tokens include:
    - `sub`: subject ID
    - `acr`: assurance level
    - `auth_time`: session timestamp
    - `trust_level`: issuer-defined tier

- SMART scopes (`launch`, `user/*.read`, etc.) dynamically registered via UDAP
- Tokens signed with ES256 or RS256
- Token bindings linked to FHIR Consent via `sourceReference`

These sessions are verifiable, revocable, and enforceable—allowing CMS-certified HIT systems to **trust who acted and why**.

5.3 Scoped Delegation and Verifiable Consent

In real-world provider workflows, iTrust Identity enables:

- Credentialed `Practitioner`, `RelatedPerson`, or `PractitionerRole` assignments
- FHIR Consent with scoped `provision.actor`, `provision.data`, and `provision.purpose`
- Session-level introspection to validate credential, trust level, and expiration
- ECDSA-signed actions logged using `AuditEvent.agent` and `Provenance.onBehalfOf`

This ensures delegated access is **authorized, bounded, and independently auditable.**

As a CARIN Alliance Member, we support provider identity verification and delegation enforcement without friction.

5.4 Certification-Ready Integration for HIT Vendors and Providers

iTrust Identity meets—and anticipates—emerging CMS and ONC certification expectations:

Capability	**Standard**	**Functionality**
Credential Interoperability	OpenID Connect + JWKS + UDAP	Federated trust across payers, providers, and CMS
Delegation Enforcement	FHIR Consent + OAuth2	Role-specific delegation and session control
Audit Logging	FHIR AuditEvent + Provenance	Traceable actor attribution and session metadata

Capability	Standard	Functionality
Session Validation	OAuth token introspection	Dynamic session enforcement based on Consent status
Bulk Export for Audit	NDJSON + FHIR $export	CMS-readable logs for delegated workflows
EHR Integration	SMART-on-FHIR + CapabilityStatement	ONC-certifiable trust layer at clinical access points

These capabilities provide the infrastructure CMS needs to **replace form-based processes with cryptographic governance.**

5.5 TEFCA-Grade Enforcement for Network Participants

iTrust Identity aligns directly with TEFCA participant obligations by enforcing:

TEFCA Requirement	iTrust Identity Enforcement
Exchange Purpose Governance	OAuth `purpose_of_use` + Consent.provision.purpose
Delegated Access Control	FHIR Provenance `onBehalfOf` + signed Consent + token introspection
Credential Validation	JWKS + OIDC discovery + CMS Trust Anchor Registry
Consent Chaining	Consent actor linking + token scoping + session metadata
Network-Wide Auditability	NDJSON `AuditEvent` + `Provenance` for cross-system traceability

This framework ensures CMS and TEFCA Participants can validate each clinical action—not just assume good faith access.

5.6 Recommendations to CMS, ONC, and the RCE

1. **Add Credential Management API requirements** to ONC HIT Certification: OIDC + OAuth + introspection

2. Mandate **Exchange Purpose enforcement** at the OAuth and Consent level for TEFCA Participants

3. Certify **Provenance.onBehalfOf** and `AuditEvent.agent` logging for all delegated workflows

4. Fund **EHR integration pilots** at FQHCs, ACOs, and state Medicaid-connected providers

5. Require TEFCA networks to recognize CMS-authorized issuers via a **federated Trust Anchor Registry**

5.7 Governance Begins at the Credential Level

With iTrust Identity, every session is authenticated, every action is scoped, and every consent is signed. Providers no longer rely on trust alone—they operate within **governable, credentialed frameworks**.

As an engaged and active Member of the CARIN Alliance, Private Identity LLC is ready to help CMS, ONC, and TEFCA stakeholders build the next generation of compliant, enforceable, and certifiable provider workflows.